

Skanowanie w praktyce

2. Skanowanie podstawowe

2.1 Wykonane polecenie

bash

```
nmap RPi_IP
```

2.2 Wyniki skanowania

```
Not shown: 989 closed tcp ports (reset)
PORT      STATE SERVICE
22/tcp    open  ssh
53/tcp    open  domain
80/tcp    open  http
81/tcp    open  hosts2-ns
443/tcp   open  https
3000/tcp  open  ppp
3001/tcp  open  nessus
5001/tcp  open  complex-link
8080/tcp  open  http-proxy
8081/tcp  open  blackice-icecap
8200/tcp  open  trivnet1
MAC Address: --:--:--:--:--:-- (Raspberry Pi (Trading))
```

Uwaga: Nazwa usługi na tym etapie to tylko przypuszczenie nmap oparte na standardowych przypisanych portów (plik `/etc/services`). Nie oznacza to, że faktycznie działa tam taka usługa.

3. Skanowanie z wykrywaniem wersji

3.1 Wykonane polecenie

```
nmap -sV RPi_IP
```

Przełącznik `-sV` (Version Detection) nawiązuje połączenia z usługami i analizuje ich odpowiedzi, aby określić faktyczną wersję oprogramowania.

```
Host is up (0.0011s latency).
Not shown: 989 closed tcp ports (reset)
PORT      STATE SERVICE      VERSION
22/tcp    open  ssh          OpenSSH 10.0p2 Debian 7+deb13u2 (protocol 2.0)
53/tcp    open  domain       dnsmasq 2.92rc1 (pi-hole)
80/tcp    open  http         OpenResty web app server
81/tcp    open  http         OpenResty web app server
443/tcp   open  ssl/https    openresty
3000/tcp  open  ppp?
3001/tcp  open  nessus?
5001/tcp  open  http         Node.js (Express middleware)
8080/tcp  open  webdav
8081/tcp  open  http         Apache httpd 2.4.66 ((Debian))
8200/tcp  open  trivnet1?
4 services unrecognized despite returning data. If you know the
service/version, please submit the following fingerprints at
https://nmap.org/cgi-bin/submit.cgi?new-service :
```

3.3 Obserwacje

Rozpoznane usługi:

- Poprawnie zidentyfikowano **8 z 11 usług**
- Wykryto dokładne wersje oprogramowania, co jest kluczowe dla oceny bezpieczeństwa

Nierozpoznane usługi:

- Porty **3000, 3001, 8200** zwróciły dane, ale nmap nie mógł dopasować ich do znanych sygnatur
- Nmap sugeruje przesłanie fingerprintów do bazy danych (opcja dla zaawansowanych użytkowników)

Czas odpowiedzi:

- Latencja **0.0011s** (1.1ms) potwierdza, że jest to maszyna w sieci lokalnej

4. Analiza powierzchni ataku

4.1 Usługi krytyczne dla bezpieczeństwa

SSH (port 22):

- Pozwala na zdalny dostęp z linii poleceń
- OpenSSH 10.0p2 to stosunkowo nowa wersja (dobra praktyka)
- Powinien być zabezpieczony: kluczami SSH, zmianą domyślnego portu, fail2ban

DNS/Pi-hole (port 53):

- Serwer DNS z funkcją blokowania reklam i złośliwych domen
- Eksponowanie na zewnątrz może być wykorzystane do ataków DNS amplification
- Powinien być dostępny tylko w sieci lokalnej

Serwery HTTP/HTTPS (porty 80, 81, 443, 5001, 8080, 8081):

- **6 różnych serwerów WWW** - duża powierzchnia ataku
- Każdy może mieć potencjalne podatności
- Różne technologie (OpenResty, Apache, Node.js) wymagają osobnego patching

6. Scenariusz 5 - Wpływ firewalla na widoczność portów

6.1 Konfiguracja zapory sieciowej (Ubuntu)

```
sudo ufw deny 80
sudo ufw status numbered
```

Powyższe polecenia blokują port 80 (HTTP) i wyświetlają numerowaną listę aktywnych reguł.

6.2 Skanowanie z maszyny atakującej (Kali)

```
nmap -p 80 RPi_IP
```

6.3 Oczekiwane wyniki w różnych scenariuszach

Scenariusz A: Firewall wyłączony (ufw inactive)

```
PORT    STATE SERVICE
80/tcp  open  http
```

Port jest widoczny jako **open** - usługa nasłuchuje i odpowiada na połączenia.

Scenariusz B: Firewall włączony z regułą deny

```
PORT    STATE  SERVICE
80/tcp  filtered http
```

Port jest widoczny jako **filtered** - pakiety są blokowane przez firewall, ale nie wiemy czy usługa faktycznie działa.

Alternatywnie (w zależności od konfiguracji):

```
PORT    STATE  SERVICE
80/tcp  closed http
```

Port może być pokazany jako **closed** jeśli firewall aktywnie odrzuca połączenia (REJECT zamiast DROP).

6.4 Porównanie stanów portów w nmap

Stan	Znaczenie	Przyczyna
open	Port otwarty, usługa odpowiada	Brak firewalla lub reguła ALLOW
filtered	Pakiety są blokowane	Firewall z regułą DROP/DENY
closed	Port zamknięty, brak usługi	Brak nasłuchującej usługi lub firewall REJECT

7. Analiza porównawcza: Firewall OFF vs ON

7.1 Firewall wyłączony (ufw inactive)

Stan przed włączeniem firewalla:

- Wszystkie 11 portów widoczne jako **open**

- Każda działająca usługa jest bezpośrednio dostępna z sieci
- Atakujący widzi pełną powierzchnię ataku
- Brak warstwy ochrony między siecią a usługami

Zagrożenia:

- Bezpośredni dostęp do wszystkich usług
- Łatwa enumeracja działających aplikacji
- Możliwość exploitowania podatności bez przeszkód
- Brak mechanizmu ograniczającego skanowanie

7.2 Firewall włączony (ufw active)

Wpływ reguły deny 80 :

- Port 80 zmienia stan z **open** na **filtered**
- Usługa nadal działa, ale jest niedostępna z zewnątrz
- Atakujący wie, że coś blokuje dostęp (firewall/router)
- Pozostałe porty wciąż widoczne (jeśli nie ma innych reguł)